

U-01 (상)	UNIX > 1. 계정 관리
	root 계정 원격 접속 제한
개요	
점검 내용	시스템 정책에 root 계정의 원격터미널 접속 차단 설정이 적용 여부 점검
점검 목적	관리자 계정 탈취로 인한 시스템 장악을 방지하기 위해 외부 비인가자의 root 계정 접근 시도를 원천적으로 차단하기 위함
보안 위협	root 계정은 운영체제의 모든 기능을 설정 및 변경이 가능하여(프로세스, 커널 변경 등) root 계정을 탈취하여 외부에서 원격을 이용한 시스템 장악 및 각종 공격으로(무차별 대입 공격, 사전 대입 공격 등) 인한 root 계정 사용 불가 위험이 존재함
참고	※ root 계정: 여러 사용자가 사용하는 컴퓨터에서 모든 기능을 관리할 수 있는 총괄 권한을 가진 유일한 특별 계정. 유닉스 시스템의 루트(root)는 시스템 관리자인 운용 관리자(Super User)로서 윈도우의 Administrator보다 높은 System 계정에 해당하며, 사용자 계정을 생성하거나 소프트웨어를 설치하고, 환경 및 설정을 변경하거나 시스템의 동작을 감시 및 제어할 수 있음 ※ 무차별 대입 공격(Brute Force Attack): 특정한 암호를 풀기 위해 가능한 모든 값을 대입하는 공격 방법 ※ 사전 대입 공격(Dictionary Attack): 사전에 있는 단어를 입력하여 암호를 알아내거나 암호를 해독하는 데 사용되는 컴퓨터 공격 방법 ※ tty(terminal-teletype): 서버와 연결된 모니터, 키보드 등을 통해 사용자가 콘솔로 직접 로그인함 ※ pts(pseudo-terminal): 가상터미널을 뜻하며, Telnet, SSH 등을 이용하여 접속함
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 원격터미널 서비스를 사용하지 않거나, 사용 시 root 직접 접속을 차단한 경우
	취약 : 원격터미널 서비스 사용 시 root 직접 접속을 허용한 경우
조치 방법	원격 접속 시 root 계정으로 접속할 수 없도록 파일 내용 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● SOLARIS

[Telnet]

Step 1) /etc/default/login 파일 내에 CONSOLE 설정값 수정

```
CONSOLE=/dev/console
```

[SSH]

Step 1) /etc/ssh/sshd_config 파일 내의 PermitRootLogin 설정값 수정

PermitRootLogin No

● **LINUX****[Telnet]**

Step 1) /etc/pam.d/login 파일 내에 auth required /lib/security/pam_securetty.so 입력

Step 2) /etc/securetty 파일 내에 pts/ 설정값 주석 처리 및 제거

#pts/0

#pts/1

#pts/2

Step 3) /etc/pam.d/login 파일 내에 모듈 추가

auth required /lib/security/pam_securetty.so

※ /etc/securetty 파일 내 pts/x 관련 설정이 존재하는 경우 PAM 모듈 설정과 관계없이 root 계정 접속을 허용하므로 반드시 제거 필요

※ CentOS 8, Ubuntu 20.04 이상부터 /etc/securetty 파일이 존재하지 않으며 기본적으로 Telnet 서비스가 비활성화됨

[SSH]

Step 1) /etc/ssh/sshd_config 파일에 PermitRootLogin 값 수정

PermitRootLogin No

● **AIX****[Telnet]**

Step 1) /etc/security/user 파일에 rlogin 설정값 수정

rlogin = false

[SSH]

Step 1) /etc/ssh/sshd_config 파일에 PermitRootLogin 값 수정

PermitRootLogin No

● HP-UX

[Telnet]

Step 1) `etc/securetty` 파일 내에 `console` 값 수정

`console`

※ `/etc/securetty` 파일은 기본적으로 존재하지 않으므로 해당 파일이 존재하지 않는 경우 생성 후 설정할 것

[SSH]

Step 1) `/opt/ssh/etc/sshd_config` 파일 내에 `PermitRootLogin` 값 수정

`PermitRootLogin No`

01. Unix 서버

U-02 (상)	UNIX > 1. 계정 관리
	비밀번호 관리정책 설정
개요	
점검 내용	비밀번호 관리 정책 설정 여부 점검
점검 목적	사용자의 비밀번호 복잡성과 주기적 변경을 통해 시스템 보안을 강화하기 위함
보안 위협	비밀번호 관련 정책이 설정되지 않을 경우, 비인가자의 각종 공격(무차별 대입 공격, 사전 대입 공격 등)에 의해 비밀번호가 노출될 위험이 존재함
참고	※ 비밀번호 관리 정책 : 비밀번호 복잡성 및 길이, 변경 주기 등을 포함한 비밀번호 정책 ※ 비밀번호 복잡성 : 비밀번호 설정 시 영문, 숫자, 특수문자를 포함하여 최소 8자리 이상
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 비밀번호 관리 정책이 설정된 경우
	취약 : 비밀번호 관리 정책이 설정되지 않은 경우
조치 방법	root 계정을 포함한 사용자 계정의 비밀번호를 영문, 숫자, 특수문자를 포함하여 최소 8자리 이상 및 최소 사용 기간 1일, 최대 사용 기간 90일, 최근 비밀번호 기억 4회 이상으로 설정
조치 시 영향	비밀번호 변경 시 Web, WAS, DB 연동 구간에서 문제가 발생할 수 있으므로 연동 구간에 미칠 수 있는 영향을 고려하여 적용 필요

점검 및 조치 사례

● SOLARIS

Step 1) /etc/default/passwd 파일 내에 비밀번호 설정값 수정

```
HISTORY=4
PASSLENGTH=8
MINDIGIT=1
MINUPPER=1
MINLOWER=1
MINSPECIAL=1
WHITESPACE=NO
```

권고값	기능	설명
HISTORY= 10	이전 비밀번호 기억 개수	이전 10개의 암호를 기억함
MINDIFF= 4	이전 암호와 차이	이전 암호와 4자 이상 차이 요구
MINALPHA= 1	최소 문자 요구	최소 1자 이상 문자 요구
MINNONALPHA= 1	최소 숫자 또는 특수문자 요구	숫자 또는 특수문자 1자 이상 요구
MINUPPER= 1	최소 대문자 요구	최소 1자 이상 대문자 요구
MINLOWER= 1	최소 소문자 요구	최소 1자 이상 소문자 요구
MAXREPEATS= 0	연속 문자 사용 허용	0일 경우 문자 연속 사용이 불가
MINSPECIAL= 1	최소 특수문자 요구	최소 1자 이상 특수문자 요구
MINDIGIT= 1	최소 숫자 요구	최소 1자 이상 숫자 요구
NAMECHECK= YES	아이디와 비밀번호 동일 검증	아이디와 동일한 비밀번호 사용 불가
MAXDAYS= 90	비밀번호 최대 유효일 수	최대 90일 비밀번호가 유효
MINDAYS= 1	비밀번호 변경 최소일 수	비밀번호 최소 1일 후 변경 가능
MAXWEEKS= 12	비밀번호 최대 유효 주 수	최대 12주 비밀번호가 유효
MINWEEKS= 1	비밀번호 변경 최소일 수	비밀번호 최소 일주일 후 변경 가능
WARNWEEKS= 1	비밀번호 만료 전 알림 주 수	비밀번호 만료 일주일 전 알림
PASSLENGTH= 8	비밀번호 최소 길이	비밀번호 최소 길이 8
WHITESPACE= NO	비밀번호 공백문자 사용 여부	비밀번호에 공백문자 사용 금지 설정

※ MINDIGIT, MINSPECIAL 설정이 적용되어 있는 경우 MINNONALPHA 설정은 적용되지 않음

※ MINDAYS 설정이 적용되어야 MAXDAYS 설정이 적용됨

※ 비밀번호 유효일 설정과 비밀번호 유효 주 설정은 중복 설정 불가함

※ WHITESPACE 기본값: YES

● LINUX

[Redhat]

Step 1) /etc/login.defs 파일에 PASS_MAX_DAYS / PASS_MIN_DAYS 값 수정

```
PASS_MAX_DAYS 90
```

```
PASS_MIN_DAYS 0
```

Step 2) /etc/security/pwquality.conf 파일에 정책 값 수정

```
minlen = 8
```

```
dcredit = -1
```

```
ucredit = -1
```

```
lcredit = -1
```

```
ocredit = -1
```

```
enforce_for_root
```

Step 3) /etc/security/pwhistory.conf 파일에 값 추가 및 수정

```
enforce_for_root
```

```
remember=4
```

```
file = /etc/security/opasswd
```

Step 4) /etc/pam.d/system-auth 파일에 값 수정

Step 5) /etc/login.defs 파일에 PASS_MAX_DAYS / PASS_MIN_DAYS 값 수정

```
PASS_MAX_DAYS 90
```

```
PASS_MIN_DAYS 1
```

※ pam_pwquality.so, pam_pwhistory.so 모듈은 pam_unix.so 모듈 위에 위치해야 적용됨

※ /etc/security/pwquality.conf 파일과 /etc/pam.d/system-auth 파일 중 어느 하나라도 비밀번호 관리 정책이 설정되어 있으면 양호

※ 비밀번호 복잡성 설정에서 최소 요구 항목의 값은 반드시 -1로 설정되어야 함

※ /etc/pam.d/system-auth 파일에 enforce_for_root 추가

[Debian]

Step 1) /etc/security/pwquality.conf 파일에 정책 값 수정

```
minlen = 8
```

```
dcredit = -1
```

```

ucredit = -1
lcredit = -1
ocredit = -1
enforce_for_root

```

Step 2) /etc/pam.d/common-password 파일에 정책 값 수정

pam_pwquality.so, pam_pwhistory.so 모듈은 pam_unix.so 모듈 위에 위치해야 적용됨

Step 3) /etc/login.defs 파일에 값 수정

```

PASS_MAX_DAYS 90
PASS_MIN_DAYS 1

```

권고값	기능	설명
difok = N	기존 비밀번호와 비교	기존 비밀번호에 포함되지 않는 문자를 최소 N개 이상 포함하도록 설정
minlen = 8	최소 비밀번호 길이 설정	최소 8자리 이상 설정
dcredit = -1	최소 숫자 요구	최소 숫자 1자 이상 요구
ucredit = -1	최소 대문자 요구	최소 대문자 1자 이상 요구
lcredit = -1	최소 소문자 요구	최소 소문자 1자 이상 요구
ocredit = -1	최소 특수문자 요구	최소 특수문자 1자 이상 요구
remember = N	최근 비밀번호 기억	최근 변경한 비밀번호를 N개 이상 기억하여 동일한 비밀번호로 변경하지 못하도록 설정
PASS_MIN_DAYS = 1	비밀번호 최소 사용 기간 설정	비밀번호 최소 사용 기간 설정 (단위 : 일)
PASS_MAX_DAYS = 90	비밀번호 최대 사용 기간 설정	비밀번호 최대 사용 기간 설정 (단위 : 일)

※ /etc/security/pwquality.conf 파일과 /etc/pam.d/common-password(/etc/pam.d/system-auth) 파일 중 어느 하나라도 비밀번호 관리 정책이 설정되어 있으면 양호

※ 비밀번호 복잡성 설정에서 최소 요구 항목의 값은 반드시 -1로 설정되어야 함

※ /etc/pam.d/system-auth 파일에 enforce_for_root 추가

● AIX

Step 1) etc/security/user 파일에 정책 값 수정

```

default :
    minage = 1
    maxage = 12
    minalpha = 2
    minother = 2

```

01. Unix 서버

```
minspecialchar = 1
```

```
minlen = 8
```

```
mindiff = 4
```

```
histsize = 4
```

권고값	기능	설명
histexpire= N	동일한 비밀번호 재사용 기간	비밀번호 재사용에 필요한 시간 (단위 : 주)
histsize= 4	이전 비밀번호 기억 개수	허용 비밀번호 반복 횟수
maxrepeats= 2	반복 가능한 동일 문자의 최대 수	비밀번호에서 반복될 수 있는 최대 문자 수
minalpha= 2	최소 알파벳 문자 포함	비밀번호에 필요한 최소 영문자 수
minother= 2	최소 알파벳 문자 이외의 문자 수	비밀번호에 필요한 최소 알파벳을 제외한 문자 수
minspecialchar= 1	최소 특수문자 포함	비밀번호에 필요한 최소 특수문자 수
mindiff= 4	이전 비밀번호와 동일 문자 수	이전 비밀번호와 구별되는 새 비밀번호의 최소 문자 수
minlen= 8	비밀번호 최소 길이	최소 비밀번호 길이
minage= 1	비밀번호 최소 사용 기간	비밀번호 변경에 필요한 최소 기간 (단위 : 주)
maxage= 12	비밀번호 최대 사용 기간	비밀번호 변경에 필요한 최대 시간 (단위 : 주)

● HP-UX

Step 1) /etc/default/security 파일에 정책 값 수정

```
MIN_PASSWORD_LENGTH=8
```

```
PASSWORD_MIN_UPPER_CASE_CHARS=1
```

```
PASSWORD_MIN_LOWER_CASE_CHARS=1
```

```
PASSWORD_MIN_DIGIT_CASE_CHARS=1
```

```
PASSWORD_MIN_SPECIAL_CASE_CHARS=1
```

```
PASSWORD_MAXDAYS=90
```

```
PASSWORD_MINDAYS=1
```

```
HISTORY=4
```

권고값	기능	설명
MIN_PASSWORD_LENGTH= 8	비밀번호 최소 길이	최소 비밀번호 길이
PASSWORD_MIN_UPPER_CASE_CHARS= 1	최소 대문자 필요 개수	비밀번호에 필요한 최소 대문자 수
PASSWORD_MIN_LOWER_CASE_CHARS= 1	최소 소문자 필요 개수	비밀번호에 필요한 최소 소문자 수

권고값	기능	설명
R_CASE_CHARS= 1		
PASSWORD_MIN_DIGIT_CHARS= 1	최소 숫자 필요 개수	비밀번호에 필요한 최소 숫자 수
PASSWORD_MIN_SPECIAL_CHARS= 1	최소 특수문자 필요 개수	비밀번호에 필요한 최소 특수문자 수
PASSWORD_MINDAYS= 1	비밀번호 최소 사용 기간	비밀번호 변경에 필요한 최소 기간 (단위 : 일)
PASSWORD_MAXDAYS= 90	비밀번호 최대 사용 기간	비밀번호 변경에 필요한 최대 시간 (단위 : 일)
HISTORY= 4	이전 비밀번호 기억 개수	허용 비밀번호 반복 횟수

[부적절한 비밀번호 유형]

사전에 나오는 단어나 이들의 조합

길이가 너무 짧거나 NULL(공백)인 비밀번호

키보드 자판의 일련의 나열(예시 : abcd, qwert 등)

사용자 계정 정보에서 유추 가능한 단어들(예시 : 지역명, 부서명, 계정명, 사용자 이름 이니셜, root, admin 등)

[비밀번호 관리 방법]

영문, 숫자, 특수문자를 조합하여 계정명과 다른 8자 이상의 비밀번호 설정

1. 다음 각 항목의 문자 종류 중 2종류 이상을 조합하여 최소 10자리 이상 또는 3종류 이상을 조합하여 최소 8자리 이상의 길이로 구성

가. 영문 대문자(26개)

나. 영문 소문자(26개)

다. 숫자(10개)

라. 특수문자(32개)

2. 시스템마다 다른 비밀번호 사용

3. 비밀번호를 기록해 놓는 경우 변형하여 기록

01. Unix 서버

U-03 (상)	UNIX > 1. 계정 관리
	계정 잠금 임계값 설정
개요	
점검 내용	사용자 계정 로그인 실패 시 계정 잠금 임계값이 설정 여부 점검
점검 목적	계정 탈취 목적의 무차별 대입 공격 시 해당 계정을 잠금으로써 인증 요청에 응답하는 리소스 낭비를 차단하고 대입 공격으로 인한 비밀번호 노출 공격을 무력화하기 위함
보안 위협	계정 잠금 임계값이 설정되어 있지 않을 경우, 비밀번호 탈취 공격(무차별 대입 공격, 사전 대입 공격, 추측 공격 등)의 인증 요청에 대해 설정된 비밀번호가 일치할 때까지 지속적으로 응답하여 해당 계정의 비밀번호가 유출될 위험이 존재함
참고	※ 사용자 로그인 실패 임계값 : 시스템에 로그인 시 몇 번의 로그인 실패에 로그인을 차단할 것인지 결정하는 값
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 계정 잠금 임계값이 10회 이하의 값으로 설정된 경우
	취약 : 계정 잠금 임계값이 설정되어 있지 않거나, 10회 이하의 값으로 설정되지 않은 경우
조치 방법	계정 잠금 임계값을 10회 이하로 설정
조치 시 영향	- HP-UX: Trusted Mode로 전환 시 파일 시스템 구조가 변경되어 운영 중인 서비스에 문제가 발생할 수 있으므로 충분한 테스트를 거친 후 Trusted Mode로의 전환이 필요함 - LINUX: /etc/pam.d/system-auth 파일 설정 시 라이브러리(/lib/security/pam_tally.so)가 해당 경로에 존재하는지 확인 필요 (존재하지 않는 파일의 경로로 설정하는 경우 시스템 로그인에 장애가 발생할 수 있음) - PAM 모듈을 이용하여 설정할 때 해당 순서를 지키지 않을 경우, 로그인 실패 또는 인증 실패 등 예기치 못한 상황이 발생할 수 있으므로 반드시 순서에 맞게 설정해야 함

점검 및 조치 사례

● SOLARIS

[5.9 미만 버전]

Step 1) /etc/default/login 파일에 RETRIES 값 수정

RETRIES=10

[5.9 이상 버전]

Step 1) /etc/security/policy.conf 파일에 LOCK_AFTER_RETRIES 값 수정

LOCK_AFTER_RETRIES=YES

UNLOCK_AFTER =2m

옵션	설명
RETRIES	로그인 시도 횟수
LOCK_AFTER_RETRIES	로그인 시도 횟수와 같거나 초과 되면 잠금 여부
UNLOCK_AFTER	잠금시간 분(m), 시(h), 일(d), w(주) 단위로 설정 가능

● LINUX

[Redhat 계열의 pam_tally.so 또는 pam_tally2.so]

Step 1) /etc/pam.d/system-auth 파일에 deny 값 수정

auth required /lib/security/pam_tally.so 또는 /lib/security/pam_tally2.so deny=10 unlock_time=120 no_magic_root

account required /lib/security/pam_tally.so 또는 /lib/security/pam_tally2.so no_magic_root reset

※ /etc/pam.d/system-auth 파일 수정 시 모듈이 해당 경로에 존재하지 않을 경우, 모든 계정의 로그인에 되지 않는 등 예기치 못한 상황이 발생할 수 있으므로 반드시 올바른 경로를 작성해야 함

[Redhat 계열의 authselect]

Step 1) # authselect enable-feature with-faillock 입력하여 faillock 적용

authselect current

Profile ID: sssd

Enabled features:

- with-fingerprint
- with-silent-lastlog
- with-faillock

Step 2) etc/securiy/faillock.conf 파일에 정책 값 수정

silent

deny = 10

unlock_time = 120

[Redhat 계열의 pam_faillock.so]

Step 1) /etc/pam.d/system-auth 파일에 모듈 값 수정

```
auth required pam_faillock.so preauth silent audit deny=10 unlock_time=120
```

Step 2) /etc/pam.d/password-auth 파일에 모듈 값 수정

```
auth required pam_faillock.so preauth silent audit deny=10 unlock_time=120
```

※ RHEL 8 이상부터 authselect 명령어를 이용하여 설정하는 것을 권장함

[Debian 계열의 pam_tally.so 또는 pam_tally2.so]

Step 1) /etc/pam.d/common-auth 파일에 모듈 값 수정

```
auth required /lib/security/pam_tally.so 또는 /lib/security/pam_tally2.so deny=10 unlock_time=120
no_magic_root
account required /lib/security/pam_tally.so 또는 /lib/security/pam_tally2.so no_magic_root reset
```

[Debian 계열의 pam_faillock.so]

Step 1) /etc/pam.d/common-auth 파일에 pam_faillock.so 모듈 값 수정

```
# here are the per-package modules (the "Primary" block)
auth      required      pam_faillock.so preauth audit deny=10 unlock_time=120
auth      [success=2 default=ignore] pam_unix.so nullok
auth      [success=1 default=ignore] pam_sss.so use_first_pass
# here's the fallback if no module succeeds
auth      [default=die]    pam_faillock.so authfail audit deny=10 unlock_time=120
auth      sufficient      pam_faillock.so authsucc audit deny=10 unlock_time=120
auth      requisite       pam_deny.so
# prime the stack with a positive return value if there isn't one already;
# this avoids us returning an error just because nothing sets a success code
# since the modules above will each just jump around
auth      required       pam_permit.so
```

[/etc/pam.d/common-auth]

Step 2) etc/pam.d/common-account 파일에 pam_faillock.so 모듈 값 수정

```
account required pam_permit.so
# and here are more per-package modules (the "Additional" block)
account sufficient pam_localuser.so
account [default=bad success=ok user_unknown=ignore] pam_sss.so
# end of pam-auth-update config
account required pam_faillock.so
```

[/etc/pam.d/common-account]

- ※ /etc/pam.d/* 파일 수정 시 모듈이 해당 경로에 존재하지 않을 경우, 모든 계정의 로그인에 되지 않는 등 예기치 못한 상황이 발생할 수 있으므로 반드시 올바른 경로를 작성해야 함
- ※ no_magic_root, reset 옵션은 pam_faillock.so 모듈에서 기본으로 작동함
- ※ audit : 실패한 로그인 시도, 잠금 조치, 계정 차단 등의 이벤트를 로그에 기록하는 옵션
- ※ silent : 비밀번호 인증 실패 시 사용자에게 세부적인 오류 메시지를 표시하지 않는 옵션

● AIX

Step 1) /etc/security/user 파일에 loginretries 값 수정

```
loginretries = 3
```

● HP-UX

[11.v2 이하 버전]

Step 1) /tcb/files/auth/system/default 파일에 u_maxtries 값 수정

```
u_maxtries#3
```

- ※ HP-UX 서버에 계정 잠금 정책 설정을 위해서는 HP-UX 서버가 Trusted Mode로 동작하고 있어야 하므로 Trusted Mode로 전환 후 잠금 정책 적용

[11.v3 이상 버전]

Step 1) /etc/default/security 파일에 AUTH_MAXTRIES 값 수정

```
AUTH_MAXTRIES=3
```

- ※ Standard 모드와 Shadow 모드만 적용 가능

옵션	설명
no_magic_root	root 계정은 비밀번호 잠금 설정을 적용하지 않음
deny=N	N회 입력 실패 시 계정 잠금
unlock_time	계정이 잠긴 경우, 마지막 계정 실패 시간부터 설정된 시간이 지나면 자동으로 계정 잠금 해제 (단위 : 초)
reset	접속 시도 성공 시 실패한 횟수 초기화

01. Unix 서버

U-04 (상)	UNIX > 1. 계정 관리
	비밀번호 파일 보호
개요	
점검 내용	시스템의 사용자 계정(root, 일반 사용자) 정보가 저장된 파일(/etc/passwd, /etc/shadow 등)에 사용자 계정 비밀번호가 암호화 저장 여부 점검
점검 목적	일부 오래된 시스템의 경우 /etc/passwd 파일에 비밀번호가 평문으로 저장되므로 사용자 계정 비밀번호가 암호화되어 저장되어 있는지 점검하여 비인가자의 비밀번호 파일 접근 시에도 사용자 계정 비밀번호가 안전하게 관리되고 있는지 확인하기 위함
보안 위협	사용자 계정 비밀번호가 저장된 파일이 유출 또는 탈취 시 평문으로 저장된 비밀번호 정보가 노출 위험이 존재함
참고	※ pwconv: 쉘도우 비밀번호 정책 ※ pwunconv: 일반 비밀번호 정책
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : 쉘도우 비밀번호를 사용하거나, 비밀번호를 암호화하여 저장하는 경우
	취약 : 쉘도우 비밀번호를 사용하지 않고, 비밀번호를 암호화하여 저장하지 않는 경우
조치 방법	비밀번호 암호화 저장·관리 설정
조치 시 영향	HP-UX 경우 Trusted Mode로 전환 시 파일 시스템 구조가 변경되어 운영 중인 서비스에 문제가 발생할 수 있으므로 충분한 테스트를 거친 후 Trusted Mode로의 전환이 필요함

점검 및 조치 사례

● SOLARIS, LINUX

Step 1) /etc/passwd 입력 후 파일 내 두 번째 필드가 x 표시되는지 확인

```
root:x:0:0:root:/root:/bin/bash
```

Step 2) # pwconv 명령으로 쉘도우 비밀번호 적용

※ SOLARIS 11은 pwunconv 명령어가 존재하지 않음

● AIX

Step 1) /etc/security/passwd 파일에 암호화 여부 확인

※ AIX는 기본적으로 /etc/security/passwd 파일에 비밀번호를 암호화하여 저장·관리함

● HP-UX

Step 1) /etc/passwd 파일에 암호화 확인

Step 2) # pwconv 명령으로 쉘도우 비밀번호 적용

※ HP-UX 서버는 Trusted Mode로 전환할 경우 비밀번호를 암호화하여 /tcb/files/auth 디렉터리에 계정 이니셜과 계정 이름에 따라 파일로 저장·관리할 수 있으므로 Trusted Mode인지 확인 후 UnTrusted Mode인 경우 모드를 전환함

※ Trusted mode 전환 방법 : root계정으로 아래 명령어 실행

/etc/tsconvert

※ UnTrusted mode 전환 방법 : root계정으로 아래 명령어 실행

/etc/tsconvert -r

※ HP-UX 11.11의 경우 Shadow Password Bundle을 설치하여야 /etc/shadow 파일 생성됨

01. Unix 서버

U-05 (상)	UNIX > 1. 계정 관리
	root 이외의 UID가 '0' 금지
개요	
점검 내용	사용자 계정 정보가 저장된 파일(/etc/passwd, /etc/shadow 등)에 root(UID=0) 계정과 동일한 UID를 가진 계정이 존재 여부 점검
점검 목적	root 계정과 동일한 UID가 존재하는지 점검하여 root 권한이 일반 사용자 계정이나 비인가자의 접근 위협에 안전하게 보호되고 있는지 확인하기 위함
보안 위협	- root 계정과 동일한 UID가 설정되어 있는 일반 사용자 계정도 root 권한을 부여받아 관리자가 실행할 수 있는 모든 작업이 가능한 위험이 존재함(서비스 시작, 중지, 재부팅, root 권한 파일 편집 등) - root 계정과 동일한 UID를 사용하므로 사용자 감사 추적 시 어려움 발생 위험이 존재함
참고	※ UID(User Identification): 여러 명의 사용자가 동시에 사용하는 시스템에서 사용자가 자신을 대표하기 위해 쓰는 이름 ※ OS마다 UID 체계가 달라 시스템 계정 및 일반 사용자 계정이 부여받는 값의 범위에 차이가 있으나, 관리자는 공통으로 UID=0을 부여받음
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : root 계정과 동일한 UID를 갖는 계정이 존재하지 않는 경우
	취약 : root 계정과 동일한 UID를 갖는 계정이 존재하는 경우
조치 방법	- UID가 0으로 설정된 계정을 0 이외의 중복되지 않은 UID로 변경 또는 불필요한 계정인 경우 제거하도록 설정 (사용 중인 계정인 경우 명령어를 통한 조치가 적용되지 않을 수 있으므로 /etc/passwd 파일을 통해 변경)
조치 시 영향	해당 계정에 관리자 권한이 필요하지 않으면 일반적으로 영향 없음

점검 및 조치 사례

● SOLARIS, LINUX, AIX, HP-UX

Step 1) usermod 명령어를 이용하여 # usermod -u <변경할 UID> <사용자 이름> 명령으로 0 이외의 중복되지 않는 UID로 변경

계정명	UID값	GID값	홈디렉토리 위치
Test	x	500	500
Gen-User	/home/test	/usr/bin/bash	
패스워드	설명(comment)	지정된 셸	

[/etc/passwd 파일 구조]

※ “:”(콜론)을 사용하여 필드를 구분함

※ 세 번째 필드(UID)가 0인 경우 슈퍼 유저 권한을 가지며, 0 이외의 계정은 일반, 시스템 계정으로 볼 수 있음

U-06 (상)	UNIX > 1. 계정 관리
	사용자 계정 su 기능 제한
개요	
점검 내용	su 명령어 사용을 허용하는 사용자를 지정한 그룹이 설정 여부 점검
점검 목적	su 관련 그룹만 su 명령어 사용 권한이 부여되어 있는지 점검하여 su 그룹에 포함되지 않은 일반 사용자의 su 명령 사용을 원천적으로 차단하는지 확인하기 위함
보안 위협	무분별한 사용자 변경으로 타 사용자 소유의 파일을 변경할 수 있으며 root 계정으로 변경하는 경우 관리자 권한을 획득할 수 있는 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	SOLARIS, LINUX, AIX, HP-UX 등
판단 기준	양호 : su 명령어를 특정 그룹에 속한 사용자만 사용하도록 제한된 경우 ※ 일반 사용자 계정 없이 root 계정만 사용하는 경우 su 명령어 사용 제한 불필요
	취약 : su 명령어를 모든 사용자가 사용하도록 설정된 경우
조치 방법	PAM 모듈 설정 또는 su 명령어 허용 그룹 생성 후 su 명령어 일반 사용자 권한 제거하도록 설정
조치 시 영향	그룹에 추가된 계정들은 모든 Session 종료 후 재 로그인 시 su 명령어 사용 가능

점검 및 조치 사례

● SOLARIS, AIX, HP-UX

Step 1) /etc/group 파일 내 wheel 그룹 (su 명령어 사용 그룹) 및 그룹 내 구성원 존재 여부 확인

Step 2) ls -l /usr/bin/su 입력 후 wheel 그룹이 su 명령어를 사용할 수 있는지 설정 여부 확인

Step 3) wheel group 생성 (wheel 그룹이 존재하지 않는 경우)

```
# groupadd wheel
su 명령 그룹 변경
# chgrp wheel /usr/bin/su
su 명령어 권한 변경
# chmod 4750 /usr/bin/su
wheel 그룹에 su 명령 허용 계정 등록
# usermod -G wheel <username>
또는 직접 /etc/group 파일을 수정하여 필요한 계정 등록
wheel:x:10: -> wheel:x:10:root,admin
```

● LINUX

[PAM 모듈 이용 중이지 않을 경우]

Step 1) /etc/group 파일 내 wheel 그룹(su 명령어 사용 그룹) 확인

Step 2) ls 명령어를 이용하여 # ls -l /usr/bin/su 입력 후 su 명령어 그룹과 권한 확인

Step 3) wheel group 생성 (wheel 그룹이 존재하지 않는 경우)

```
# groupadd wheel
```

su 명령 그룹 변경

```
# chgrp wheel /usr/bin/su
```

su 명령어 권한 변경

```
# chmod 4750 /usr/bin/su
```

wheel 그룹에 su 명령 허용 계정 등록

```
# usermod -G wheel <username>
```

※ /etc/group 파일에서 기본 그룹의 경우 사용자 이름은 생략되며 자동으로 포함됨

[PAM 모듈 이용 중인 경우]

Step 1) /etc/group 입력 후 wheel 그룹(su 명령어 사용 그룹) 확인

예시) wheel:x:1002:

Step 2) etc/pam.d/su 파일 내 su 명령어 허용 그룹 확인

Step 3) usr/bin/su 파일 내 su 명령어 그룹과 권한 확인

Step 4) /etc/pam.d/su 파일에 모듈 값 수정

```
auth                required pam_wheel.so use_uid
```

또는

```
auth                required pam_wheel.so group=wheel
```